

La protection CSRF

Vous allez créer une application Laravel simple où un utilisateur peut soumettre un formulaire. Nous allons expérimenter avec et sans la protection CSRF pour observer son importance.

1. Créer un nouveau projet Laravel

Exécutez la commande suivante pour créer un nouveau projet Laravel :

```
composer create-project laravel/Laravel:^12 csrf-app
cd csrf-app
php artisan serve
```

Accédez à l'application dans votre navigateur à <http://127.0.0.1:8000>.

2. Créer un formulaire simple

Ajoutez une nouvelle route dans **routes/web.php** :

```
use Illuminate\Support\Facades\Route;
use Illuminate\Http\Request;

Route::get('/form', function () {
    return view('form');
});

Route::post('/submit', function (Request $request) {
    return 'Formulaire soumis avec succès : ' . $request->input('name');
});
```

Créez ensuite le fichier de vue **resources/views/form.blade.php** :

```
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Formulaire CSRF</title>
</head>
<body>
    <h1>Soumission d'un formulaire</h1>
    <form method="POST" action="/submit">
        <!-- Jeton CSRF -->
        @csrf
        <label for="name">Nom :</label>
        <input type="text" id="name" name="name" required>
        <button type="submit">Envoyer</button>
    </form>
</body>
</html>
```

3. Tester la soumission avec CSRF

Rendez-vous à <http://127.0.0.1:8000/form>.

Remplissez le formulaire et cliquez sur "**Envoyer**".

Vous devriez voir un message confirmant que le formulaire a été soumis.

4. Désactiver la protection CSRF

Pour simuler une attaque CSRF, désactivez temporairement la protection dans **routes/web.php** :

```
use Illuminate\Foundation\Http\Middleware\VerifyCsrfToken;

Route::post('/submit', function (Request $request) {
    return 'Formulaire soumis avec succès : ' . $request->input('name');
})->withoutMiddleware([VerifyCsrfToken::class]);
```

Ensuite, rechargez le formulaire, et essayez de soumettre une requête sans le jeton CSRF :

Supprimez la ligne **@csrf** dans **form.blade.php**.

Rechargez le formulaire et envoyez-le. Vous verrez que la soumission fonctionne même sans le jeton.

5. Simuler une attaque CSRF

Crée un fichier **attaque.html** (n'importe où, hors du projet Laravel) :

```
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Attaque CSRF</title>
</head>
<body>
    <h2>Tu ne te rends compte de rien...</h2>
    <form method="POST" action="http://127.0.0.1:8000/submit">
        <input type="hidden" name="name" value="Hacker">
        <button type="submit">Clique ici pour gagner un cadeau !</button>
    </form>
</body>
</html>
```

Ouvrez ce fichier dans un navigateur, puis cliquez sur le bouton.

Si la protection CSRF est désactivée, la requête sera acceptée. Sinon, elle sera bloquée.

6. Réactiver la protection CSRF

Supprimez **/submit** de l'exception dans **VerifyCsrfToken.php**, et réactivez **@csrf** dans **form.blade.php**.

EXPLICATIONS

Avec CSRF activé : Laravel ajoute un jeton unique dans chaque formulaire. Si une requête ne contient pas ce jeton, Laravel bloque la requête.

Sans CSRF : Un attaquant peut créer un formulaire malveillant et forcer un utilisateur connecté à envoyer des requêtes non autorisées.